

SGSI-UNCP

Programa Maestro de Auditoría Basada en Riesgos (Ciclo 2026)

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Programa Maestro de Auditoría Basada en Riesgos (Ciclo 2026)
 - 1.1 Objetivos del Programa de Auditoría 2026
 - 1.2 Clasificación de Auditorías por Nivel de Riesgo
 - 1.3 Cronograma Detallado Q1–Q4 2026
 - 1.4 Recursos y Presupuesto
 - 1.5 Seguimiento y Cierre

1. Programa Maestro de Auditoría Basada en Riesgos (Ciclo 2026)

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Comité de Gobierno Digital
Norma: ISO/IEC 27001:2022 (Cláusula 9.2 – Auditoría Interna) **Metodología:** P-SGSI-09 (Metodología de Auditoría Basada en Riesgos y Procesos) **Alineamiento:** R-SGSI-03 (KPIs), D-SGSI-05 (SoA), PGTD-01 (Implementación SGSI)

1.1. Objetivos del Programa de Auditoría 2026

1. Verificar la implementación y eficacia del 100 % de los controles declarados en la SoA (D-SGSI-05).
2. Evaluar la madurez de los procesos críticos del SGSI (Cl. 4–10 de ISO 27001:2022).
3. Identificar no conformidades y oportunidades de mejora con al menos 120 días de anticipación a la Etapa 1 de certificación (Q1 2027).
4. Evaluar la efectividad del CSIRT Universitario mediante simulacros de ransomware y phishing.
5. Validar el cumplimiento del Reglamento de Protección de Datos Personales (D.S. 016-2024-JUS) en procesos que tratan datos sensibles.

1.2. Clasificación de Auditorías por Nivel de Riesgo

De acuerdo con P-SGSI-09 (Sección 2), las auditorías se asignan a procesos según su nivel de riesgo:

Nivel de Riesgo	Frecuencia	Prioridad para 2026
Crítico	Semestral	Gestión de Accesos, Resiliencia/Continuidad, Seguridad Física
Alto	Anual	Desarrollo Seguro, Incidentes, Proveedores, Privacidad
Medio	Anual o bienal	Capacitación, Eliminación Segura, Control Documental
Bajo	Bienal o a demanda	Procesos administrativos menores

1.3. Cronograma Detallado Q1–Q4 2026

1.3.1. Q1 (Ene–Mar) — Accesos e Identidades

Micro-Auditoría	ID Plan	Cláusulas / Controles	Alcance	Riesgo	Duración Estimada
Gestión de Accesos y Altas/Bajas	AUD-2026-001	A.5.15–A.5.18, P-SGSI-03, POL-SGSI-06	Personal administrativo, docentes, proveedores	Crítico	3 días
Verificación de SoA	AUD-2026-002	Cl. 6.1.3, D-SGSI-05	Consistencia de controles planificados vs. implementados	—	1 día

1.3.2. Q2 (Abr–Jun) — Seguridad en Desarrollo y APIs

Micro-Auditoría	ID Plan	Cláusulas / Controles	Alcance	Riesgo	Duración Estimada
Seguridad en Desarrollo de Software	AUD-2026-003	A.8.25–A.8.30, POL-SGSI-01	Ciclo de vida del ERP ADESA y APIs	Alto	5 días
Seguridad en APIs	AUD-2026-004	A.8.26, TRV-02 (API Gateway)	APIs internas y externas	Alto	2 días

1.3.3. Q3 (Jul–Sep) — Resiliencia, RespalDOS y Seguridad Física

Micro-Auditoría	ID Plan	Cláusulas / Controles	Alcance	Riesgo	Duración Estimada
Resiliencia y Continuidad	AUD-2026-005	A.5.30, A.8.13, POL-SGSI-03	Huawei Cloud, failover, respaldos locales+cloud	Crítico	4 días
Seguridad Física del Datacenter	AUD-2026-006	A.7.1–A.7.14, POL-SGSI-07	Datacenter principal y sala de servidores	Crítico	2 días

1.3.4. Q4 (Oct–Dic) — Incidentes, Privacidad y Cumplimiento Legal

Micro-Auditoría	ID Plan	Cláusulas / Controles	Alcance	Riesgo	Duración Estimada
Gestión de Incidentes	AUD-2026-007	A.5.24, P-SGSI-02	CSIRT Universitario, simulacro ransomware	Alto	3 días
Privacidad y Cumplimiento Legal	AUD-2026-008	Cl. 10, Ley 29733, D.L. 1412, D.S. 016-2024-JUS	Protección de datos personales en procesos misionales	Alto	3 días
Pre-auditoría de Certificación	AUD-2026-009	Cl. 4–10 + Anexo A	Preparación para certificación ISO 27001:2022	Crítico	5 días (externa)

1.4. Recursos y Presupuesto

Concepto	Tipo	Monto Estimado (S/)
Auditorías internas (Q1–Q4)	Personal interno (OTI / Oficial Seg.)	S/ 0 (costo de horas hombre)
Herramientas de escaneo de vulnerabilidades	Licencias	S/ 8,000
Acceso a dashboards Huawei Cloud	Incluido en contrato cloud	S/ 0
Pre-auditoría externa de certificación (Q4)	Consultoría externa	S/ 25,000
Simulacro de ransomware (Q4)	Plataforma de simulación	S/ 5,000
Total presupuesto auditoría 2026		S/ 38,000

1.5. Seguimiento y Cierre

1.5.1. 5.1 Plazos de Acción Correctiva

Tipo de Hallazgo	Plazo Máximo para Plan de Acción	Plazo Máximo para Cierre
No Conformidad Mayor	5 días hábiles	30 días hábiles

Tipo de Hallazgo	Plazo Máximo para Plan de Acción	Plazo Máximo para Cierre
No Conformidad Menor	15 días hábiles	60 días hábiles
Oportunidad de Mejora	30 días hábiles	90 días hábiles

1.5.2. 5.2 Reporte Mensual al CGD

El Oficial de Seguridad presentará mensualmente al Comité de Gobierno Digital: - Estado de avance del programa de auditoría - KPIs de hallazgos (KPI-13, KPI-14, KPI-15 de R-SGSI-03) - RACs abiertos con fecha de vencimiento próxima - Riesgos emergentes identificados durante las auditorías

1.5.3. 5.3 Criterios de Aceptación del Programa

El programa se considera exitoso si al cierre de 2026: - ☐ 100 % de las micro-auditorías planificadas fueron ejecutadas - ☐ 90 % de los hallazgos tienen plan de acción aprobado - ☐ 70 % de las NC menores están cerradas - ☐ No hay NC mayores sin plan de acción a 30 días del hallazgo - ☐ La pre-auditoría externa (Q4) confirma preparación para certificación

Aprobado por: Comité de Gobierno Digital **Fecha de aprobación:** 15/01/2026 **Próxima revisión del programa:** 15/04/2026 (trimestral)